

VEILLE CYBERSÉCURITÉ & PROTECTION DES INFRASTRUCTURES

Évolution des menaces, analyses forensiques et stratégies de résilience
Rapport complet de veille mensuelle BTS SIO SISR — Mai 2026

Note de présentation : Ce document technique approfondi synthétise les données opérationnelles issues de l'ANSSI (Panorama de la cybermenace publié le 11 mars 2026), du CERT-FR, de l'ENISA et des rapports gouvernementaux français de crise de mai 2026. Destiné à l'acquisition des compétences en ingénierie de sécurité pour les étudiants BTS SIO SISR.

Sommaire

- 1. Chiffres clés opérationnels — Panorama ANSSI 2025
- 2. Analyse macroscopique de la menace et positionnement stratégique de la France
- 3. Évolution fine des vecteurs d'attaque : IA offensive, exfiltration sèche, OT/IoT
- 4. Registre détaillé des incidents majeurs du mois de mai 2026
- 5. Le plan de riposte gouvernemental du 30 avril 2026 et stratégie nationale
- 6. Cadre réglementaire de la souveraineté numérique : NIS2, DORA, Cyber Resilience Act
- 7. Recommandations techniques architecturales et posture Zero Trust
- 8. Glossaire de sécurité et sources de référence

1. Chiffres clés opérationnels — Panorama ANSSI 2025

Le Panorama de la cybermenace publié le 11 mars 2026 par l'ANSSI met en exergue une stabilisation des incidents confirmés à un niveau historiquement élevé, témoignant d'une professionnalisation accrue des attaquants qui ciblent de façon préférentielle les structures à faible maturité cyber.

Événements traités	Incidents confirmés	Exfiltrations de données	Attaques par ransomware
3 586	1 366	196	128

Analyse de l'ANSSI : La baisse faciale de 18% des événements de sécurité bruts s'explique mécaniquement par la fin de l'effet de sur-vigilance et du dispositif exceptionnel déployé lors des Jeux Olympiques de Paris 2024. En revanche, le volume d'incidents réels confirmés stagne (+0,4%), confirmant une pression cyber structurelle permanente.

Répartition sectorielle des cyber-incidents validés

- 34% - Secteur Éducation et Recherche** : Universités, centres de calcul, laboratoires stratégiques. Ce secteur est devenu la cible principale en France, visant le vol de propriété intellectuelle et l'exploitation d'infrastructures pour rebondir vers d'autres SI.

- **24% - Collectivités territoriales et Ministères** : Administrations locales, mairies de toutes tailles, services ministériels déconcentrés, pénalisés par un manque de ressources budgétaires dédiées à la sécurité opérationnelle.
- **10% - Secteur de la Santé** : Établissements hospitaliers et cliniques, ciblés par des attaques par déni de service (DDoS) ou rançongiciels impactant la continuité des soins.
- **9% - Opérateurs de Télécommunications** : Infrastructures de routage, fournisseurs d'accès Internet, ciblés dans le cadre d'opérations d'espionnage et d'interception de flux de données stratégiques.
- **23% - Secteurs marchands et industriels divers** : PME, ETI industrielles, acteurs logistiques, entreprises du secteur de l'énergie et de l'eau (OIV/OSE).

2. Analyse macroscopique de la menace et positionnement stratégique de la France

« Un casse du siècle qui a pratiquement lieu tous les mois. »

— Sébastien Lecornu, ministre des Armées, lors du point de situation interministériel du 30 avril 2026

En mai 2026, la France consolide sa position de deuxième pays européen le plus ciblé par l'activité cybercriminelle et étatique mondiale, captant à elle seule près de 13% du volume global des attaques dirigées contre le vieux continent. Cette exposition s'explique par sa forte concentration d'infrastructures de haute technologie et son poids géopolitique. Les services de renseignement cyber enregistrent une moyenne de trois vols de données critiques par jour depuis le début de l'année civile.

Hybridation de la menace : la disparition des frontières

Le fait saillant de l'année 2026, documenté par le CERT-FR, réside dans l'effacement des frontières opérationnelles entre les attaquants étatiques (groupes APT d'espionnage) et l'écosystème cybercriminel crapuleux (groupes de ransomware). Les services étatiques recourent de plus en plus aux infrastructures de rançongiciels clés en main pour camoufler leurs opérations de sabotage ou d'espionnage sous des mobiles purement financiers. Réciproquement, les groupes criminels intègrent des techniques de persistance furtive (Living off the Land) jusqu'alors réservées aux officines étatiques.

3. Évolution fine des vecteurs d'attaque : IA offensive, exfiltration sèche, OT/IoT

■ L'Intelligence Artificielle Offensive [Critique] :

L'IA a profondément modifié la cinétique des attaques. Elle automatise désormais la réécriture de malwares polymorphes capables de contourner les solutions EDR traditionnelles, génère des campagnes de 'spear-phishing' basées sur l'analyse automatisée des profils LinkedIn des cibles, et orchestre des deepfakes audio d'une fidélité absolue pour exécuter des fraudes au président de nouvelle génération.

■ L'Exfiltration Sèche (Pure Extortion) [Surveillance] :

Le chiffrement des serveurs par ransomware tend à reculer au profit de l'exfiltration sèche de données. Cette approche permet aux attaquants de contourner les politiques de

sauvegarde (backups hors ligne). L'attaquant extrait furtivement plusieurs téraoctets de données sensibles, puis exige une rançon sous peine de divulgation publique ou de revente aux concurrents, réduisant le bruit généré par le chiffrement et retardant la détection.

■ Vulnérabilités de la convergence IT / OT [Élevé] :

Les systèmes de contrôle industriels (SCADA, automates programmables) sont de plus en plus interconnectés aux réseaux informatiques d'entreprise. L'IA permet d'analyser en temps réel les schémas industriels exfiltrés pour concevoir des charges utiles ciblant l'outil de production. On dénombre désormais en moyenne 144 identités machines pour une seule identité humaine au sein des SI modernes, constituant un vecteur d'attaque privilégié dénué de double authentification.

4. Registre détaillé des incidents majeurs du mois de mai 2026

- **Cyberattaque contre l'ANTS — 15 avril / Mai 2026** : Le portail France Titres a subi une exfiltration massive via une faille de type Zero-Day exploitée sur un serveur d'authentification tiers. Les données de 12 millions de dossiers ont été extraites. L'ANSSI a procédé au durcissement des SI étatiques.
- **Mairie de Quiberon — Épisode Qilin du 6 mai 2026** : L'infrastructure municipale de la ville de Quiberon a été entièrement paralysée par le groupe cybercriminel Qilin (opérant sous un modèle RaaS). Les sauvegardes en ligne ayant été compromises, l'ensemble de l'état civil, de la gestion des écoles et des services administratifs a dû basculer sur un mode dégradé papier pendant trois semaines. Les attaquants exigeaient une rançon en crypto-actifs pour fournir la clé de déchiffrement.
- **Warner Bros France — Campagne de déni de service et défacement (Mars - Mai 2026)** : Plusieurs sous-domaines web officiels de la filiale française ont été ciblés de manière répétée par des collectifs d'hacktivistes (Simsimi, Vandathegod). L'attaque a combiné des saturations de serveurs par déni de service distribué (DDoS) et des modifications cosmétiques des pages d'accueil (défacement), mettant en évidence des faiblesses de configuration chez les hébergeurs tiers.
- **Filière du Tourisme Français — Attaque ciblée ChimeraZ (Mai 2026)** : Un acteur malveillant opérant sous l'identifiant ChimeraZ a publié sur un forum spécialisé du darkweb des extraits de bases de données hautement critiques ciblant les systèmes de réservation, les plannings de transport et les fichiers clients de plusieurs grands groupements hôteliers et agences de voyage français. L'attaque s'est appuyée sur l'exploitation d'une vulnérabilité présente dans un plugin de réservation largement diffusé.

5. Le plan de riposte gouvernemental du 30 avril 2026 et stratégie nationale

Face à la recrudescence des compromissions touchant les systèmes d'information de l'État (notamment l'ANTS et l'ANFR), le Premier ministre a ordonné le déploiement d'un plan de riposte interministériel d'urgence s'articulant autour de trois piliers directeurs :

• Pilier 1 — Enveloppe d'urgence et réaffectation budgétaire :

Mobilisation immédiate d'une enveloppe de 200 millions d'euros issue des fonds non alloués du programme France 2030 pour financer la mise à niveau cyber des infrastructures

d'importance vitale. Une disposition législative nouvelle prévoit que l'intégralité du produit des amendes administratives prononcées par la CNIL sera désormais fléchée et affectée de façon exclusive à un fonds souverain de modernisation numérique de l'État.

• **Pilier 2 — Refonte institutionnelle (Fusion DINUM / DITP) :**

Dissolution des structures actuelles et fusion de la Direction Interministérielle du Numérique (DINUM) et de la Direction Interministérielle de la Transformation Publique (DITP). Cette fusion donne naissance à une autorité unique et centralisée du numérique de l'État, directement rattachée aux services du Premier ministre. Elle dispose d'un pouvoir d'injonction technique pour imposer un socle commun de sécurité logicielle à l'ensemble des ministères.

• **Pilier 3 — Durcissement opérationnel et Règle des 5% :**

L'ANSSI reçoit pour instruction de mener des campagnes de tests d'intrusion de masse (red teaming / pentests agressifs) sur l'intégralité des plateformes publiques connectées à Internet. Par ailleurs, une règle budgétaire contraignante impose désormais à toutes les administrations et ministères de consacrer un minimum strict de 5% de leur budget informatique global au volet cybersécurité et protection des réseaux.

6. Cadre réglementaire de la souveraineté numérique : NIS2, DORA, Cyber Resilience Act

■ **Directive NIS2 :**

Législation européenne transposée en droit national visant à harmoniser et élever la résilience cyber de 18 secteurs d'activité critiques. Elle élimine la distinction antérieure entre OIV et OSE pour classer les entités en entités importantes ou essentielles. Elle impose la mise en œuvre de 10 mesures de sécurité obligatoires (gouvernance, hygiène cyber, chiffrement, gestion des vulnérabilités de la supply chain) et contraint les structures à notifier l'ANSSI de tout incident significatif sous un délai de 24 heures (alerte initiale) puis 72 heures (rapport complet). Le taux de conformité mesuré à la mi-2026 s'établit à seulement 62% des structures assujetties en France.

■ **Règlement DORA :**

Texte ultra-contraignant sectoriel ciblant la résilience opérationnelle informatique du secteur financier. Il impose aux banques, assurances et tiers technologiques d'établir un cadre de gestion des risques technologiques (TIC), de notifier les incidents de manière centralisée, de conduire des tests de robustesse annuels (exigence de Threat-Led Penetration Testing pour les entités systémiques) et de cartographier finement la dépendance vis-à-vis des prestataires cloud extérieurs. Trois fintechs françaises de premier plan ont subi un gel réglementaire de leurs activités en 2026 suite au constat répété de failles majeures dans leurs plans de continuité.

■ **Cyber Resilience Act (CRA) :**

Règlement européen imposant des exigences cyber obligatoires applicables à tous les produits comportant des éléments numériques mis sur le marché européen (matériels IoT, logiciels, micrologiciels). Il introduit le concept de 'Security by Design' en contraignant les fabricants à documenter l'absence de vulnérabilités connues avant commercialisation, à fournir des mises à jour de sécurité gratuites pendant toute la durée de vie du produit (ou

pour un minimum de 5 ans) et à notifier l'ENISA de toute faille activement exploitée dans un délai de 24 heures.

7. Recommandations techniques architecturales et posture Zero Trust

Architecture réseau et contrôle d'accès

[OK] Implémentation stricte du modèle Zero Trust : Appliquer le paradigme fondamental : 'Ne jamais faire confiance, toujours vérifier'. Supprimer la notion de réseau de confiance interne.

[OK] Micro-segmentation réseau (SDN) : Isoler de manière logique les différents flux applicatifs, segmenter les réseaux de production des environnements de test, et cantonner les architectures industrielles (OT) dans des zones étanches.

[OK] Gouvernance et cartographie des identités machines : Mettre en œuvre des solutions de gestion des accès à privilèges (PAM) pour encadrer, auditer et renouveler de façon automatisée les secrets logiques utilisés par les machines et les APIs tierces.

Supervision active et détection des menaces

[OK] Déploiement d'un SOC souverain 24/7/365 : Assurer une collecte centralisée de l'ensemble des journaux d'événements (logs) via une solution SIEM couplée à des briques d'analyse comportementale (UEBA).

[OK] Généralisation des EDR/XDR durcis : Remplacer les antivirus traditionnels par des agents EDR capables d'analyser l'activité mémoire des serveurs et terminaux et d'isoler automatiquement une machine suspecte du réseau.

Gestion des tiers et résilience logicielle

[OK] Exigence systématique du SBOM : Exiger de tous les fournisseurs de logiciels un inventaire structuré de l'ensemble des composants open-source et bibliothèques tierces intégrés.

[OK] Durcissement des processus de sauvegarde (Immuabilité) : Mettre en place des architectures de sauvegarde immuables (Write Once Read Many - WORM) et déconnectées (air-gapped).

8. Glossaire de sécurité et sources de référence

- **APT** : Advanced Persistent Threat. Groupe d'attaquants hautement qualifié, souvent adossé à un État.
- **CRA** : Cyber Resilience Act. Législation européenne sur la sécurité native des produits numériques connectés.
- **EDR** : Endpoint Detection and Response. Logiciel de surveillance continue et de détection comportementale sur les postes et serveurs.

- **OT** : Operational Technology. Informatique industrielle pilotant les équipements physiques et vannes d'infrastructures.
- **RaaS** : Ransomware as a Service. Modèle d'affiliation où des développeurs louent leur code malveillant à des attaquants.
- **SBOM** : Software Bill of Materials. Inventaire formel des composants et dépendances logicielles d'une application.
- **Zero Trust** : Modèle de sécurité basé sur l'authentification continue de tout utilisateur et équipement, sans confiance implicite.

Sources opérationnelles consultées

- ANSSI — Panorama de la cybermenace 2025, document officiel de l'agence nationale (publié le 11 mars 2026).
- CERT-FR — Rapports d'analyse technique et bulletins d'alertes forensiques (janvier-mai 2026).
- Secrétariat Général de la Défense et de la Sécurité Nationale (SGDSN) — Compte-rendu du plan d'action interministériel du 30 avril 2026.
- ZATAZ.com — Veille et investigations sur les fuites de bases de données criminelles (mai 2026).